



Registro Ufficiale dei Rilievi d'Audit ISO/IEC 27001:2022 & NIST CSF v1.1

Standard di Riferimento: ISO 19011:2018, ISO/IEC 27001:2022 & NIST CSF v1.1

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: AUD-NC-2026-03

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Per Uso d'Audit

Data di Efficacia: Agosto 2026

1. Scopo e Metodologia di Classificazione (ISO 19011)

Il presente documento costituisce la **Matrice Ufficiale dei Rilievi (NC/OFI Matrix)** risultante dall'audit di conformità e gap analysis condotto presso **Aetheris Therapeutics S.p.A.**.

Ogni rilievo è stato categorizzato secondo le definizioni dello standard **ISO 19011:2018**:

* **NC Major (Non-Conformità Maggiore):** Assenza totale o fallimento sistemico di una clausola obbligatoria ISO 27001 o di un controllo critico. Blocca il rilascio della certificazione e richiede un'Azione Correttiva immediata.

* **NC Minor (Non-Conformità Minore):** Singola lacuna procedurale o applicazione parziale di un controllo che non compromette l'intero SGSI.

* **OFI (Opportunity for Improvement):** Suggerimento tecnico/organizzativo per elevare il livello di maturità del sistema.

Per ciascun rilievo viene definita la **Causa Radice (Root Cause)** e il relativo **Piano di Azione Correttiva (CAPA)** con i tempi di risoluzione previsti.

2. Sintesi Quantitativa dei Rilievi

Categoria Rilievo	Quantità Ricontrata	Impatto sulla Certificazione ISO 27001
NC Major (Maggiori)	5	Bloccante — Remediation obbligatoria prima dello Stage 2
NC Minor (Minori)	4	Critico — Richiede piano di azione correttiva entro 90 giorni
OFI (Opportunità Miglioramento)	3	Raccomandato — Implementazione valutata in sede di riesame
PASS (Conformi)	4	Conforme — Mantenimento e monitoraggio continuo

3. Registro Dettagliato delle Non-Conformità Maggiori (NC Major)

NC-MAJ-01: Assenza di Multi-Factor Authentication (MFA) sugli Accessi Remoti VPN

- **Riferimento ISO 27001:** Annex A.5.15 (Access Control) & Annex A.8.5 (Secure Authentication)
- **Riferimento NIST CSF:** PR.AC-3 (Remote Access Management)
- **Evidenza d'Audit:** L'analisi della configurazione del gateway VPN ha mostrato che le connessioni remote per dipendenti e consulenti si basano esclusivamente su credenziali statiche (username e password) senza il secondo fattore di autenticazione.
- **Analisi Causa Radice (Root Cause):** Mancanza di integrazione tra l'Infrastruttura VPN locale e l'Identity Provider Azure AD/MFA; priorità di budget precedentemente assegnata solo alle licenze base.

- **Azione Correttiva (CAPA):** Applicazione dell'MFA obbligatorio tramite Azure AD / Conditional Access per tutte le sessioni VPN remote.
 - **Target Remediation: 30 Giorni | Owner:** Systems Administrator
-

NC-MAJ-02: Gestione Condivisa delle Credenziali Amministrative e Assenza di PAM

- **Riferimento ISO 27001:** Annex A.5.18 (Access Rights) & Annex A.8.2 (Privileged Access Rights)
 - **Riferimento NIST CSF:** PR.AC-4 (Access Permissions)
 - **Evidenza d'Audit:** Durante l'esame di Active Directory e dei server di ricerca R&D, è emerso che le utenze con privilegi Domain Admin sono condivise tra più sistemisti senza tracciabilità individuale o soluzioni di Privileged Access Management (PAM).
 - **Analisi Causa Radice (Root Cause):** Pratica operativa consolidata negli anni per comodità di gestione IT; assenza di una policy formale sugli accessi privileged.
 - **Azione Correttiva (CAPA):** Eliminazione degli account condivisi, creazione di utenze amministrative nominali e introduzione di un caveau digitale/PAM per la gestione delle password di root e admin.
 - **Target Remediation: 45 Giorni | Owner:** IT Director
-

NC-MAJ-03: Assenza di un Piano Formale di Incident Response (IRP)

- **Riferimento ISO 27001:** Clausola 5.24 & Annex A.5.26 (Response to Information Security Incidents)
 - **Riferimento NIST CSF:** RS.RP-1 (Response Plan)
 - **Evidenza d'Audit:** L'organizzazione non dispone di un documento scritto o approvato che disciplini le fasi di rilevazione, contenimento, eradicazione e notifica dei data breach o degli incidenti di sicurezza.
 - **Analisi Causa Radice (Root Cause):** Gestione della sicurezza intesa finora in ottica puramente reattiva e infrastrutturale senza governance procedurale.
 - **Azione Correttiva (CAPA):** Redazione, approvazione e test (simulation/tabletop exercise) di un Incident Response Plan conforme alle linee guida NIST SP 800-61.
 - **Target Remediation: 60 Giorni | Owner:** Cybersecurity Analyst
-

NC-MAJ-04: Mancanza del Registro dei Trattamenti dei Dati Personali (Art. 30 GDPR)

- **Riferimento ISO 27001:** Clausola 4.2 (Interested Parties) & Annex A.5.34 (Privacy & PII Protection)
 - **Riferimento NIST CSF:** ID.GV-3 (Legal & Regulatory Requirements)
 - **Evidenza d'Audit:** Non è stato esibito alcun Registro dei Trattamenti formalizzato per i dati personali e sensibili (campioni clinici e PII di pazienti) trattati nei laboratori R&D e nei sistemi aziendali.
 - **Analisi Causa Radice (Root Cause):** Assenza di un DPO dedicato e scarsa coordinazione tra il reparto Legal/HR e l'area IT.
 - **Azione Correttiva (CAPA):** Mappatura completa dei flussi dati PII, censimento delle banche dati e redazione formale del Registro Art. 30 GDPR.
 - **Target Remediation: 60 Giorni | Owner:** Legal & Compliance Lead
-

NC-MAJ-05: Assenza di un SIEM e di un Monitoraggio h24 dei Log di Sicurezza

- **Riferimento ISO 27001:** Annex A.8.15 (Logging) & Annex A.8.16 (Monitoring Activities)
- **Riferimento NIST CSF:** DE.AE-3 / DE.CM-1 (Security Monitoring & Event Correlation)
- **Evidenza d'Audit:** I log prodotti dai firewall Palo Alto, dalle macchine Azure e da Active Directory rimangono locali sui singoli dispositivi senza essere centralizzati o correlati da una piattaforma SIEM/SOC.

- **Analisi Causa Radice (Root Cause):** Costi percepiti come elevati per una struttura SOC interna e mancanza di competenze di monitoraggio h24.
 - **Azione Correttiva (CAPA):** Adozione di una soluzione SIEM cloud (es. Microsoft Sentinel) o ingaggio di un servizio MSSP/SOC gestito in outsourcing.
 - **Target Remediation: 90 Giorni | Owner:** Cybersecurity Analyst
-

4. Registro Dettagliato delle Non-Conformità Minori (NC Minor)

NC-MIN-01: Gestione Manuale e Non Automatizzata dell'Inventario Asset

- **Riferimento ISO 27001:** Annex A.5.9 (Inventory of Information and Other Associated Assets)
 - **Riferimento NIST CSF:** ID.AM-1 / ID.AM-2 (Asset & Software Management)
 - **Evidenza d'Audit:** L'inventario hardware e software è gestito tramite un foglio di calcolo Excel aggiornato manualmente dall'IT Manager, con elevato rischio di disallineamento e mancato tracciamento di Shadow IT.
 - **Analisi Causa Radice (Root Cause):** Assenza di uno strumento dedicato di IT Asset Management (ITAM) o CMDB integrato.
 - **Azione Correttiva (CAPA):** Implementazione di un sistema di discovery automatica degli asset di rete ed endpoint.
 - **Target Remediation: 90 Giorni | Owner:** IT Director
-

NC-MIN-02: Policy di Sicurezza IT Non Aggiornata né Approvata dalla Direzione

- **Riferimento ISO 27001:** Clausola 5.2 (Policy) & Annex A.5.1 (Policies for Information Security)
 - **Riferimento NIST CSF:** ID.GV-1 (Organizational Cybersecurity Policy)
 - **Evidenza d'Audit:** La Policy IT aziendale risale a oltre due anni fa, non integra i riferimenti al cloud Azure e non reca la firma formale di approvazione del CEO.
 - **Analisi Causa Radice (Root Cause):** Assenza di un ciclo di riesame periodico stabilito per la documentazione di governance.
 - **Azione Correttiva (CAPA):** Revisione complessiva della politica di sicurezza, formalizzazione del controllo versione e approvazione formale della Direzione.
 - **Target Remediation: 60 Giorni | Owner:** Lead Auditor / GRC Specialist
-

NC-MIN-03: Criteri di Screening del Personale Non Uniformi nell'Onboarding HR

- **Riferimento ISO 27001:** Annex A.6.1 (Screening)
 - **Riferimento NIST CSF:** PR.AT-1 (Personnel Security)
 - **Evidenza d'Audit:** Le verifiche di background per i neo-assunti vengono eseguite in modo saltuario e non sono formalizzate in una procedura standard applicata a tutti i ruoli R&D e IT.
 - **Analisi Causa Radice (Root Cause):** Processo di onboarding HR focalizzato sugli aspetti amministrativi anziché sui controlli di sicurezza.
 - **Azione Correttiva (CAPA):** Definizione di una check-list formale di screening HR per tutte le posizioni a contatto con asset critici o dati PII.
 - **Target Remediation: 90 Giorni | Owner:** HR Manager
-

NC-MIN-04: Assenza di Clausole di Audit Cyber nei Contratti di Fornitura SaaS

- **Riferimento ISO 27001:** Annex A.5.19 (Information Security in Supplier Relationships)
- **Riferimento NIST CSF:** ID.SC-3 (Supplier Risk Management)

- **Evidenza d'Audit:** I contratti stipulati con i fornitori di servizi cloud/SaaS terzi non includono clausole sul diritto di audit, sui requisiti minimi di sicurezza o sui tempi di notifica di un data breach.
- **Analisi Causa Radice (Root Cause):** Contratti d'acquisto gestiti senza il preventivo vaglio dell'ufficio Legal/Security.
- **Azione Correttiva (CAPA):** Inserimento di un addendum di sicurezza (Security Annex) standardizzato per tutti i contratti con fornitori critici.
- **Target Remediation: 120 Giorni | Owner:** Legal & Compliance Lead

5. Registro delle Opportunità di Miglioramento (OFI)

💡 OFI-01: Adozione di Soluzioni EDR (Endpoint Detection and Response)

- **Riferimento ISO 27001:** Annex A.8.7 (Protection Against Malware) | **Riferimento NIST:** DE.CM-4
- **Descrizione:** Sulle workstation R&D è presente un antivirus tradizionale basato su firme. Si raccomanda il passaggio a una soluzione EDR gestita centralmente per rilevare minacce comportamentali evolute e ransomware.

💡 OFI-02: Attuazione di Programmi di Phishing Simulation Periodici

- **Riferimento ISO 27001:** Annex A.6.3 (Information Security Awareness) | **Riferimento NIST:** PR.AT-2
- **Descrizione:** La formazione aziendale è limitata a corsi teorici iniziali. Si suggerisce di pianificare campagne trimestrali di simulazione di attacchi phishing per misurare e incrementare il livello reale di consapevolezza del personale.

💡 OFI-03: Automazione dei Controlli DLP (Data Loss Prevention)

- **Riferimento ISO 27001:** Annex A.8.12 (Data Leakage Prevention) | **Riferimento NIST:** PR.DS-4
- **Descrizione:** Si consiglia l'attivazione dei moduli DLP nativi di Microsoft 365 per prevenire la condivisione o la fuga accidentale verso l'esterno di documenti contenenti formule molecolari, brevetti o dati clinici sensibili.

6. Riepilogo dei Controlli Conformi (PASS)

- **PASS-01 — Segmentazione della Rete R&D (Annex A.8.20 / PR.AC-5):** Isolamento efficace dei laboratori di ricerca dalla rete aziendale generica tramite Next-Gen Firewall Palo Alto.
- **PASS-02 — Immutabilità e Cifratura dei Backup (Annex A.8.13 / PR.IP-4):** Backup notturni cifrati ed immutabili salvati su repository Azure Storage isolati.
- **PASS-03 — Controllo degli Accessi Fisici ai Laboratori (Annex A.7.2 / PR.AC-2):** Monitoraggio varchi e accessi ai laboratori R&D garantiti da badge nominali e videosorveglianza h24.
- **PASS-04 — Cifratura dei Dispositivi Utente (Annex A.8.24 / PR.DS-1):** BitLocker attivo con cifratura integrale del disco su tutti i laptop aziendali distribuiti.

7. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026